행정안전부 청원 첨부 보고서

# 보안프로그램 10개 깔아놓고 3년간 해킹당한 행정시스템

클라이언트 보안프로그램 과잉 설치 해소 및
서버사이드 보안(제로트러스트) 전환 종합 보고서

**(주) 옥소폴리틱스**

대표 유호현

2026년 3월

## 1 현황: 공무원 PC에 무엇이 깔려 있나

현재 공무원 행정망 PC에는 다음과 같은 보안프로그램이 **동시에** 설치·구동되고 있습니다.

| # | 프로그램 종류 | 역할 | 작동 레벨 |
|---|---|---|---|
| 1 | **문서보안(DRM)** | 문서 자동 암호화/복호화 | 커널 |
| 2 | **네트워크접근제어(NAC)** | 미인가 단말 접속 차단 | 커널 |
| 3 | **백신(Antivirus)** | 악성코드 탐지 | 커널 |
| 4 | **매체제어** | USB/외장하드 통제 | 커널 |
| 5 | **DLP(정보유출방지)** | 파일 외부 전송 차단 | 커널 |
| 6 | **키보드보안** | 키로깅 방지 | 커널 |
| 7 | **개인방화벽** | 네트워크 트래픽 제어 | 커널 |
| 8 | **패치관리(PMS)** | 보안 업데이트 강제 적용 | 시스템 |
| 9 | **GPKI 인증모듈** | 행정전자서명 | 시스템 |
| 10 | **화면캡처방지** | 스크린샷 차단 | 커널 |
| 11+ | **프린트제어 외** | 출력 통제 등 | 다양 |

> **핵심 문제:** 이 프로그램들 대부분이 **커널 레벨**(운영체제 최상위 권한)에서 작동합니다. 하나라도 버그가 있으면 PC 전체가 위험해집니다. 그런 프로그램이 10개 이상 동시에 돌아갑니다.

---

**집 보안을 강화한다면서 문을 10개 더 뚫어놓은 셈이다.**
**하나만 부실해도 도둑이 들어온다.**

---

## 2 5가지 핵심 문제

### 문제 1: PC 성능 저하 — 업무가 안 됩니다

- 부팅에 수 분 소요 — 보안프로그램이 순차적으로 로드
- CPU·메모리 과점유 — 아무 작업 안 해도 리소스 50% 이상 소모
- 문서 열기, 인터넷 검색 등 기본 업무가 느림
- 공무원 커뮤니티(클리앙, DC 등)에서 "보안프로그램이 컴퓨터 속도를 저하시키는 악의 축"이라는 불만 지속
- 민간에서는 '구라 제거기'로 불필요한 보안프로그램을 일괄 삭제할 정도지만, 관공서 PC에서는 사용 불가

### 문제 2: 보안프로그램 간 충돌

- 여러 커널 레벨 프로그램이 동시 작동 → 시스템 오류·블루스크린 발생
- 보안 프로그램 A가 보안 프로그램 B를 악성코드로 오탐지하는 사례
- 재부팅으로 해결해야 하지만 업무 중 재부팅 어려움
- 전산팀이 환경 설정 변경 권한을 차단하여 사용자가 직접 최적화 불가

### 문제 3: 보안프로그램이 오히려 해킹 통로

**KAIST 연구 (2025년 6월, USENIX Security 2025):**

- 김용대·윤인수 교수팀이 국내 7종 주요 금융보안프로그램 분석
- **19건의 심각한 보안 취약점** 발견
- 키보드 입력 탈취, 중간자 공격, 인증서 탈취, 원격 코드 실행 가능
- 보안프로그램이 브라우저 자체 보안 구조(샌드박스)를 **우회하도록 설계**되어 있어 오히려 공격 면적을 넓힘
- 논문 제목: "Too Much of a Good Thing" — 좋은 것도 너무 많으면 해가 된다

### 문제 4: 온나라시스템 3년간 해킹

**사건 개요:**

- 2022년 9월 ~ 2025년 7월: 약 **3년간** 해커가 온나라시스템에 무단 접속
- GPKI 인증서 **650건 유출** (12건은 비밀번호까지 노출)
- 해커가 GPKI 인증서를 탈취하여 정부원격근무서비스(GVPN)를 통해 침입
- 미국 해킹 잡지 **Phrack**이 2025년 8월 공격 방법을 공개한 후에야 발견
- **10종 이상의 보안프로그램을 깔아놓고도 3년간 몰랐습니다.**

**이 사건이 증명하는 것:** 클라이언트 PC에 보안프로그램을 아무리 많이 깔아도, 서버 측 보안이 부실하면 무의미합니다. 해커는 보안프로그램이 깔린 PC가 아니라, 인증 체계(GPKI)를 공격했습니다. 클라이언트 보안은 실패했고, 서버사이드 보안(제로트러스트)으로 전환해야 하는 이유가 입증됐습니다.

## 문제 5: AI 시대 대응 불가

- 보안프로그램이 PC 자원을 과점유 → AI 도구 구동 불가
- 네트워크 통제 → 클라우드 AI 서비스 접근 차단
- 선진국 공무원: AI로 업무 시간 30~50% 절감 중
- 한국 공무원: AI 접근 자체가 차단되어 경험도 쌓이지 않음
- 싱가포르: 공무원 전원에게 AI 도구 제공 + 교육 의무화
- 미국: 연방정부 AI.gov 가이드라인 + 공무원 AI 활용 지원

## 3 보안프로그램을 통한 실제 해킹 사례

**2020년**

**북한 라자루스 그룹 — Veraport 공급망 공격**

은행·정부 사이트의 보안프로그램 관리자(Veraport)를 해킹. 한국 보안업체 2곳의 디지털 인증서를 탈취하여 악성코드를 정상 프로그램으로 위장. 보안프로그램 자동 설치 기능으로 사용자 PC에 악성코드 배포. (ESET 보고)

**2023년**

**북한 해커 — MagicLine4NX 제로데이**

의무 설치 보안프로그램 MagicLine4NX의 취약점을 이용해 기업 내부 네트워크 침투. 영국 정보기관(NCSC)과 한국 국가정보원(NIS)이 공동 경보 발령. 직원에게는 이 프로그램을 안 깔 권리가 없었음.

**2023년**

**TouchEn nxKey — 전 국민 키보드 취약점**

보안 연구자 Wladimir Palant가 키보드 보안 프로그램 TouchEn nxKey에서 7개 취약점 발견. 악성 웹사이트가 이 프로그램을 이용해 전 국민의 키보드 입력을 가로챌 수 있었음. Chrome 웹스토어 1,000만+ 설치, 평점 1.3/5.

**2022~2025년**

**온나라시스템 — GPKI 인증서 탈취**

해커가 GPKI 인증서 650건을 탈취하여 정부 행정망에 3년간 무단 접속. 10종 이상의 보안프로그램이 설치된 환경에서 발생. Phrack 잡지 공개 후 발견.

**2025년**

**KAIST — 금융보안프로그램 19개 취약점**

USENIX Security 2025 학회에 "Too Much of a Good Thing" 논문 게재. 7종 프로그램에서 19건의 심각한 취약점 발견. 보안프로그램이 브라우저 보안을 우회하여 오히려 해킹 통로가 된다는 학술적 증거.

---

**보안프로그램을 깔아서 안전해진 게 아니라,**
**보안프로그램을 깔아서 뚫린 것이다.**

---

## 4 한국 vs 다른 나라

### 🇰🇷 한국 — 클라이언트 보안

"PC가 위험하니 PC에서 막겠다"

- 보안프로그램 10종+ 설치
- 커널 레벨에서 PC 전체 감시
- PC 성능 저하, 프로그램 충돌
- 보안프로그램 자체가 공격 대상

결과: 3년간 해킹당하고도 모름

### 🇺🇸 🇪🇺 미국·유럽 — 서버사이드 보안

"PC는 통제 불가, 서버에서 막겠다"

- 클라이언트 프로그램 최소화
- 제로트러스트: 모든 접근을 매번 검증
- PC는 가볍게, 보안은 서버에서
- 이상 행동 AI로 실시간 탐지

결과: PC 성능 정상, 보안 더 강력

| 나라 | 접근 방식 | 현황 |
|---|---|---|
| **미국** | 제로트러스트 | 2021년 바이든 행정명령. 연방정부 전환 중 |
| **영국** | 위험 기반 접근제어 | NCSC 가이드라인. 공무원 클라우드 사용 가능 |
| **에스토니아** | 클라우드 기반 | 전자정부 1위. 모든 공공서비스 클라우드 |
| **싱가포르** | 제로트러스트 + AI | 공무원 전원 AI 도구 제공 |
| **한국** | 클라이언트 보안 | N2SF 발표(2024)했으나 실제 전환 더딤 |

## 5 해결책: 제로트러스트란 무엇인가

```
[ 현재 — 성벽 방식 (망분리 + 클라이언트 보안) ]

"성벽을 높이 쌓고, 성 안에 있으면 안전하다고 본다"
"성 안 사람들의 집에 CCTV 10대씩 설치한다"

→ 문제: 성벽을 넘은 해커는 마음대로 돌아다닌다
→ 문제: CCTV가 너무 많아서 집(PC)에서 살기 어렵다
→ 문제: CCTV 자체가 해킹당하면 오히려 집이 더 위험해진다


[ 제로트러스트 — 신분증 방식 ]

"성벽 없이, 모든 사람이 매번 신분증을 보여줘야 한다"
"집(PC)에는 CCTV를 안 깔고, 건물 입구에서 확인한다"

→ 누가, 어디서, 어떤 기기로, 무엇에 접근하는지 매번 확인
→ PC에 프로그램을 깔 필요 없다 → PC 성능 정상
→ 이상 행동은 서버에서 AI가 실시간 탐지
→ 인터넷 차단(망분리)할 필요도 없다
```

### 국정원 N2SF — 이미 방향은 잡혔다

- 2024년 9월: 국정원이 **국가망보안정책 개선 로드맵(N2SF)** 발표
- 2025년 9월: **N2SF 보안가이드라인 1.0 정식판** 공표
- 업무·데이터를 3등급으로 분류: C(기밀), S(민감), O(공개)
- 등급별 차등 보안통제 — 모든 데이터에 최고 수준 보안을 적용할 필요 없음
- **문제: 실제 전환이 매우 느리다.** 2025년 실증사업은 4~6개 기관에 불과

## 6 청원 요구사항

**요구 1: 클라이언트 보안프로그램 축소 로드맵**

행정기관 PC에 설치되는 보안프로그램을 현재 10종 이상에서 단계적으로 축소하는 구체적 로드맵을 수립해 주십시오.

- 1단계(6개월): 기능이 중복되는 프로그램 통합 (예: 키보드보안 + DLP + 화면캡처방지 → 1개로 통합)
- 2단계(1년): 서버사이드 대체 가능한 프로그램 제거 (예: 키보드보안 → TLS 암호화로 대체)
- 3단계(2년): 필수 최소(백신 + NAC + DRM) 3종 이내로 축소

**요구 2: 제로트러스트 전환 가속화**

국정원 N2SF 가이드라인의 실제 적용을 가속화해 주십시오.

- 현재 4~6개 기관 실증 → 2026년 내 전 중앙부처 파일럿으로 확대
- 전환 목표 시한 설정: 2028년까지 전 행정기관 제로트러스트 전환 완료

**요구 3: GPKI 인증체계 현대화**

온나라시스템 해킹의 원인이 된 GPKI 인증서 체계를 현대화해 주십시오.

- GPKI 인증서 → 모바일 공무원증 기반 다중인증(FIDO2) 전환
- 인증서 파일 방식 → 생체인증(지문, 얼굴) 방식으로 전환
- 이미 행안부가 추진 방향을 발표했으나, 속도가 더딥니다

**요구 4: 보안프로그램 실효성 독립 검증**

현재 설치된 보안프로그램이 실제로 보안에 기여하는지 독립적으로 검증하는 체계를 마련해 주십시오.

- 보안프로그램 10종을 깔아놓고 3년간 해킹당한 사실을 모른 현 체계는 실패한 것입니다
- KAIST 연구처럼 독립적 학술 검증을 정기적으로 실시
- 검증 결과를 공개하여 시민이 확인할 수 있도록

## 7 실행 로드맵

| Phase | 시기 | 핵심 실행 사항 | 공무원 체감 |
|---|---|---|---|
| 1 | 6개월 | 중복 보안프로그램 통합<br>GPKI → FIDO2 파일럿<br>보안프로그램 실효성 검증 착수 | "PC가 좀 빨라졌다" |
| 2 | 1년 | 서버사이드 대체 가능한 프로그램 제거<br>제로트러스트 전 부처 파일럿<br>AI 도구 접근 허용 | "AI를 업무에 쓸 수 있다" |
| 3 | 2년 | 보안프로그램 3종 이내로 축소<br>제로트러스트 전면 전환<br>PC 2대 → 1대 통합 | "PC 한 대로 전부 된다" |

## 8 기대 효과

| 효과 | 설명 |
|---|---|
| **PC 성능 정상화** | 부팅 시간 단축, 업무 속도 향상. 공무원 생산성 즉시 개선 |
| **실질적 보안 강화** | 공격 면적(보안프로그램 10종)을 줄여 해커의 진입점 감소 |
| **AI 활용 가능** | PC 자원·네트워크 여유 확보 → AI 도구 업무 활용 가능 |
| **비용 절감** | 보안프로그램 라이선스 비용 절감 + PC 2대→1대 통합 |
| **시스템 안정성** | 보안프로그램 간 충돌·블루스크린 해소 |
| **글로벌 표준 정합** | 미국·영국과 같은 제로트러스트 체계로 국제 협력 원활 |

**보안프로그램을 더 깔아서 해결하는 시대는 끝났습니다.**
**서버에서 막고, PC는 가볍게.**

© 2026 (주) 옥소폴리틱스 | 대표 유호현

본 보고서는 청원24(행정안전부) 청원 첨부 자료로 작성되었습니다.